

API 规范总览与 AI 审查记录

1. 文档目的

本文件用于汇总 P3 阶段 API 设计成果，并记录对 AI 生成 API 草案的人工审查结论。详细接口定义分散在 `docs/P3/API规范/` 目录下的各模块文档中，本文件只保留目录、覆盖范围、统一约束和审查记录。

2. API 文档目录

文档	覆盖模块	主要接口
API规范-“用户登录与认证”部分.md	用户与认证	注册、登录、刷新令牌、获取当前用户、修改密码、登出
API规范-“代码支撑平台”部分.md	代码托管底座适配	仓库导入、仓库详情、同步、Issue 查询、分支、Commit、PR、Webhook
API规范-“任务与悬赏”部分.md	任务与悬赏	发布任务、浏览任务列表、查看任务详情、接取任务
API规范-“任务分类”部分.md	任务分类与标签	分类浏览、分类创建、分类更新、标签浏览、标签创建、标签更新
API规范-“管理员审核”部分.md	管理员审核	任务发布审核、任务退回、任务下架
API规范-“提交评价”部分.md	提交与审核反馈	维护者审核提交、逐项反馈、审核通过或退回
API规范-“推荐匹配”部分.md	推荐匹配	获取推荐任务、推荐贡献者、查询推荐理由
API规范-“新手引导”部分.md	新手引导与项目理解	获取项目结构、运行说明、贡献流程、推荐起步任务

3. P3 要求覆盖情况

P3 要求接口	对应文档	对应接口	覆盖状态
用户注册 / 登录	API规范-“用户登录与认证”部分.md	POST /api/v1/auth/login	已覆盖
发布需求	API规范-“任务与悬赏”部分.md	POST /api/v1/quests	已覆盖
浏览需求列表（含筛选）	API规范-“任务与悬赏”部分.md	GET /api/v1/quests	已覆盖
接单	API规范-“任务与悬赏”部分.md	POST /api/v1/quests/{questId}/assignments	已覆盖
查看订单详情	API规范-“任务与悬赏”部分.md	GET /api/v1/quests/{questId}	已覆盖
提交评价	API规范-“提交评价”部分.md	POST /api/v1/submissions/{submissionId}/reviews	已覆盖

说明：项目语义中“需求 / 订单”对应平台内的“任务 / 悬赏任务”。为保持领域语言统一，API命名使用 `quest`，不混用 `order`。

4. 统一 API 约束

约束项	规范说明
基础路径	所有业务接口统一使用 <code>/api/v1</code>
数据格式	请求体和响应体统一使用 JSON
认证方式	登录态通过 <code>Authorization: Bearer <JWT_TOKEN></code> 传递
响应结构	成功和失败均返回 <code>code</code> 、 <code>message</code> 、 <code>timestamp</code> 、 <code>traceId</code>
错误处理	每个模块文档独立列出业务错误码和 HTTP 状态码
权限校验	角色权限必须由后端校验，前端页面控制不能作为安全边界
分页参数	列表接口统一使用 <code>page</code> 和 <code>size</code> ，页码从 <code>1</code> 开始
幂等处理	Webhook、同步、审核等重复调用风险较高的接口必须在服务端做重复处理保护

5. AI 生成 API 草案审查记录

编号	审查维度	AI 草案问题	人工修正结果
1	接口命名	将任务接口混写为 <code>/tasks</code> 、 <code>/orders</code> 、 <code>/quests</code> ，领域语言不一致	统一使用 <code>/quests</code> 表达悬赏任务，避免接口语义漂移
2	错误处理	只给出成功响应，缺少失败响应和错误码	每份 API 文档补充业务错误码、HTTP 状态码和典型失败响应
3	参数校验	未说明必填字段、枚举值和分页边界	所有请求参数表增加类型、是否必填、枚举值和默认值
4	安全问题	接取任务、审核任务等接口在草案中允许前端传 <code>userId</code>	接取人、审核人统一从 JWT 解析，前端不传可信身份字段
5	权限边界	未区分初学者、维护者、管理员的可调用接口	在接口说明中明确角色权限，例如发布任务、管理员审核、维护者审核
6	状态流转	草案允许直接把任务改为任意状态	在接口说明中固定状态流转，例如任务发布后先进入管理员审核
7	外部平台耦合	把 GitHub OAuth 作为默认登录方式	改为平台自有账号体系；GitHub 只作为仓库导入和同步来源
8	Webhook 安全	Webhook 接口未考虑签名校验	代码支撑平台 API 增加 Webhook 签名、幂等和重复投递处理要求

6. 审查结论

AI 生成的 API 草案可以帮助快速铺开接口清单，但直接使用会产生命名不一致、权限不清晰和错误处理不足的问题。最终版本以 P1 需求和 P2 架构为准，保留 RESTful 风格，同时补足身份认证、角色权限、参数校验、错误码和外部代码托管安全约束。